

Matriz de Evaluación PRAGMATIC Completa para Métricas CMMC / NIS2 / ENS

Versión: 1.0

Nota: Puntuaciones 0–5 basadas en juicio experto; ajustar según contexto sectorial.

1. Leyenda de puntuaciones

- 0 = Nulo / No cumple.
- 1 = Muy bajo.
- 2 = Bajo.
- 3 = Aceptable.
- 4 = Bueno.
- 5 = Excelente.

2. Matriz principal

2.1. Métricas de control de acceso y MFA

Métrica	Descripción	P	R	A	G	M	A(c)	T	I	C	Total	Comentario
%_Cuentas_críticas_MFA	Porcentaje de cuentas con acceso a sistemas críticos que usan MFA robusta	4	5	5	5	5	4	4	3	4	39	Métrica central para ataques de credenciales; muy útil para gobernanza.
%_Accesos_remotos_MFA	Porcentaje de accesos remotos a sistemas críticos protegidos con MFA	4	5	5	5	5	4	4	3	3	38	Gran impacto en riesgo; datos pueden requerir cierto esfuerzo de agregación.

Nº_e xcep cione s_MF A	Núm ero de cuen tas crític as sin MFA por exce pción apro bada	3	4	4	4	4	4	3	3	4	33	Muy útil para audit oría y redu cción progr esiva de exce pcion es.
------------------------------------	---	---	---	---	---	---	---	---	---	---	----	--

2.2. Métricas de vulnerabilidades y parcheo

Métrica	Descripción	P	R	A	G	M	A(c)	T	I	C	Total	Comentario
MTT P_cri tico	Tiempo medio de parcheo de vulnerabilidades críticas en sistemas expuestos	4	5	5	4	4	4	3	3	3	35	Fuertemente correlacionado con probabilidad de explotación.
%_Sistemas_cumpl en_SLA_parcheo_critico	Porcentaje de sistemas que cumplen el plazo objetivo de parcheo	4	5	5	4	4	4	3	3	3	35	Métrica muy adecuada para cuadros de mando y acuerdos de nivel de servicio internos.

Medi a_vul n_cri ticas _por _acti vo	Núm ero medi o de vulne rabili dade s crític as abier tas por activ o crític o	3	4	4	4	4	3	3	3	3	31	Útil, pero pued e ser más sensi ble a error es de inve ntari o.
--	--	---	---	---	---	---	---	---	---	---	----	--

2.3. Métricas de monitorización y respuesta (MTTD / MTTR)

Métrica	Descripción	P	R	A	G	M	A(c)	T	I	C	Total	Comentario
MTT D_in ciden tes_s ignifi cativ os	Tiem po medi o de detección de incid entes signif icativ os	5	5	5	4	4	3	3	3	3	35	Mé tr ica estrel la para SOC, aunq ue requi ere defin ición clara de “inci dente signif icativ o”.
MTT R_inc ident es_si gnific ativo s	Tiem po medi o de recu peración/c onte nción	5	5	5	4	4	3	3	3	3	35	Direc tame nte relaci onad a con impa cto de nego cio.
%_In ciden tes_c on_p ostm orte m	Porce ntaje de incid entes con análi sis y plan de acción	4	4	4	4	4	4	3	3	4	34	Impu lsa la mejo ra conti nua, relati vame nte barat a de medi r.

2.4. Métricas de clasificación y cifrado de información sensible

Métrica	Descripción	P	R	A	G	M	A(c)	T	I	C	Total	Comentario
%_Activos_datos_clasificados	Porcentaje de activos de datos sensibles formalmente clasificados	4	5	4	4	4	3	3	3	3	33	Requiere un esfuerzo inicial de clasificación; excelente para madurez estratégica.
%_Datos_sensibles_cifrados_en_reposo	Porcentaje de datos sensibles cifrados en reposo	4	5	5	4	4	4	3	3	3	35	Métrica clave para cumplimiento ENS/RGPD/NIS2.

%_Ca nales _sen sible s_cifr ados _en_ trans ito	Porce ntaje de canal es que trans porta n datos sensi bles con cifra do robu sto	4	5	5	4	4	4	3	3	3	35	Muy útil para audit orías técni cas y revisi ones de arqui tectu ra.
--	--	---	---	---	---	---	---	---	---	---	----	--

2.5. Métricas de proveedores y cadena de suministro

Métrica	Descripción	P	R	A	G	M	A(c)	T	I	C	Total	Comentario
%_Proveedores_criticos_identificados	Porcentaje de proveedores críticos formalmente identificados	3	5	4	4	4	3	3	3	3	32	Condición necesaria para todo lo demás; muy alineada con NIS2 /DO RA.
%_Contratos_criticos_con_clausulas_seguridad_robustas	Porcentaje de contratos críticos con requisitos de seguridad verificables	4	5	5	4	4	4	3	4	3	36	Fuerte impacto en gobernanza de terceros; indicador muy valioso.

%_Proveedores críticos evaluados anualmente	Porcentaje de proveedores críticos evaluados con métricas	4	5	5	4	4	3	3	3	3	34	Refuerza la supervisión continua de la cadena de suministro.
--	---	---	---	---	---	---	---	---	---	---	----	--

2.6. Métricas de formación, cultura y comportamiento

Métrica	Descripción	P	R	A	G	M	A(c)	T	I	C	Total	Comentario
%_Plantilla_formativa_anual	Porcentaje de plantilla con formación anual en ciberseguridad	3	5	4	4	4	4	3	3	4	34	Métrica casi obligatoria, fácil de obtener.
Tasa_click_phishing	Porcentaje de usuarios que caen en simulaciones de phishing	4	5	5	4	4	3	3	3	3	34	Muy accionable, pero requiere cuidado en la gestión cultural.

Nº_r eport es_v olunt arios _por _100 _em plea dos	Repo rtes volu ntari os de incid entes por cada 100 empl eado s	4	4	4	4	4	3	3	3	3	33	Buen indic ador de cultu ra de repor te, no tan trivia l de medi r de form a hom ogén ea.
---	---	---	---	---	---	---	---	---	---	---	----	--

2.7. Métricas de documentación y evidencias

Métrica	Descripción	P	R	A	G	M	A(c)	T	I	C	Total	Comentario
Estado_SS P (0-4)	Nivel de existencia /actualización del SSP	3	5	4	4	4	3	3	3	3	32	Sintética y muy usada en CM MC; algo subjetiva si no se define bien la escala.
%_Control_con_evidencias_actualizadas	Porcentaje de controles con evidencias vigentes	4	5	5	4	4	4	3	3	3	35	Indicador potente de calidad de cumplimiento.
%_Acciones_POAM_completadas_en_plazo	Porcentaje de acciones de mejora completadas en plazo	4	5	5	4	4	4	3	3	3	35	Conecta claramente con la mejora continua.

3. Selección de métricas “estrella”

Se pueden considerar como métricas prioritarias aquellas con ≥ 34 puntos, por ejemplo:

- %_Cuentas_criticas_MFA
- %_Accesos_remotos_MFA
- MTTP_critico
- MTTD_incidentes_significativos
- MTTR_incidentes_significativos
- %_Datos_sensibles_cifrados_en_reposo
- %_Canales_sensibles_cifrados_en_transito
- %_Contratos_criticos_con_clausulas_seguridad_robustas
- %_Plantilla_formacion_anual
- Tasa_clicks_phishing
- %_Controles_con_evidencias_actualizadas
- %_Acciones_POAM_completadas_en_plazo

Estas son las mejores candidatas para figurar en cuadros de mando ejecutivos y en informes nacionales sectoriales.

Fin de la Matriz de Evaluación PRAGMATIC.